Risk Management in Cyber Security

Vulnerability Assessment

Risk management in cyber security

- This is simply a structured process of identifying, assessing, treating, and continuously monitoring cyber risks so that an organization's exposure stays within its risk appetite while supporting business objectives. National Institute of Standards and Technology (NIST) says that it involves assessing risks, implementing mitigation strategies, and continuously monitoring security controls.
- The objective or aim of risk management includes the following:
- Prioritize limited resources towards the most important risks and not necessarily the Highest CVSS score.
- Protect sensitive information from cyber threats
- Reduce financial loses from security incidences
- Maintain business continuity
- Meet legal and regulatory requirements

Common risk management frameworks

- **NIST cybersecurity framework (CSF) 2.0** which provides guidance for understanding, assessing, and reducing cybersecurity risks using a common organizational approach.
- **NIST SP 800-30 Rev. 1 (Guide for conducting Risk Assessments)** Practical methods to identify threats and vulnerabilities, estimate likelihood and impact, and determine risks.
- **SP 800-53 – Security and privacy controls** for federal information systems; commonly mapped to enterprise control libraries and used in audits
- **ISO/IEC 27005:** which provides guidance on managing information security risks and supports the implementation of an information security management system (ISMS) under ISO?IEC 27005.
- Please take note on the references for NIST and ISO/IEO 2005 and read more on information security to have international knowledge about protecting the information security in an organisation.

Remediation Vs Mitigation

ASPECT	REMEDIATION	MITIGATION
Aim	Permanently fixes the vulnerability	Reduces likelihood or impact of exploitation
Root cause	Eliminated	Still present
Typical measure	Patches, upgrades, configurations, and code fixes	Segmentation, access controls WAF, rules, use of firewalls disabling features, air gapping, monitoring
Duration	Long term / permanent for the vulnerability	Temporally or conditional
Ideal scenario	Fix available and deployable	No fix yet, or fix too disruptive to apply immediately.
Goal	Fully fix the vulnerability so that the specific vulnerability no longer exists	Reduce risk when a full fix is not yet possible , too disruptive or unavailable
Effect on risk	Removes the root cause and the vulnerability is considered closed or validated	Lowers the chances of successful exploitation or limits damage

Components of risks in an information system – Qualitative

- The simple way to estimate cybersecurity risk is as follows:
- **Risk = Likelihood * Impact**
- Where **Likelihood** is the **probability** that a **threat** will **exploit** a **vulnerability**.
- And **impact** is the **damage** or **consequences** if the event occurs. NIST describes a risk as a function of the likelihood of occurrence and the adverse impact of that occurrence.
- A risk matrix could be a simple matrix or 3 * 3 or 5 * 5 or more. Our discussions will be around a 5 * 5 risk matrix.
- A **risk matrix** is a tool used to evaluate and priorities risks by considering Likelihood (how likely the event is to occur) and impact or consequences (how severe the consequences would be if it occurred).
- Each factor is scored from 1 to 5 in the event of a 5 * 5 risk matrix, and the scores are multiplied to determine the overall risk rating.

5 * 5 Risk matrix

- This is a **two -axis grid** that turns qualitative judgements about likelihood and impact into a single risk score (1-25) and a risk level such as Low, Medium, High and severe/Critical/Catastrophic.
- **Y-Axis (rows): Likelihood/Probability** – usually labeled from 1 (Rare) to 5 (Almost certain).
- **X-Axis (columns): Impact/damage/consequences** – usually labelled from 1 (Insignificant/Negligible) to 5 (Catastrophic/Severe) .

How to read a specific risk

1. Rate **likelihood** on the 1-5 scale using your definitions e.g. Rare, Unlikely, Possible, Almost certain
2. Rate **Impact** on the scale 1-5 e.g. Insignificant, minor, moderate, major, catastrophic
3. Find the cell where that row and column meet. The number in that cell is the risk score = Likelihood * Impact (range 1-25)
4. Map the score to a risk level using your organization’s band as follows;

Likelihood – Probability

Score	Likelihood	Description
1	Rare	Unlikely to occur
2	Unlikely	Could occur occasionally
3	Possible	Might occur at some time
4	Likely	Will probably occur
5	Almost certain	Expected to occur frequently

Impact – Consequences

Score	Impact	Description
1	Insignificant	Minimal effect
2	Minor	Small disruption or injury
3	Moderate	Noticeable impact
4	Major	Serious consequences
5	Catastrophic	Severe injury, major loss, or business shutdown

5 * 5 Risk Matrix

Impact / Likelihood	1 – Rare	2 – Unlikely	3 – Possible	4 – Likely	5 – Almost certain
5 – Catastrophic	5	10	15	20	25
4 – Major	4	8	12	16	20
3 – Moderate	3	6	9	12	15
2 – Minor	2	4	6	8	10
1 – Insignificant	1	2	3	4	5

Typical Risk Matrix a 5 * 5 - Qualitative risk management



Probability
What is the probability the risk will happen?

	Insignificant 1	Minor 2	Significant 3	Major 4	Severe 5
5 Almost Certain	Medium 5	High 10	Very high 15	Extreme 20	Extreme 25
4 Likely	Medium 4	Medium 8	High 12	Very high 16	Extreme 20
3 Moderate	Low 3	Medium 6	Medium 9	High 12	Very high 15
2 Unlikely	Very low 2	Low 4	Medium 6	Medium 8	High 10
1 Rare	Very low 1	Very low 2	Low 3	Medium 4	Medium 5

Typical score band explained

- Organizations vary but common mappings are as follows with regard to the table above;
- 1-4 or 1-5: Low (Green) Monitor/accept
- 5-10 or 6 -12/14: Medium (Yellow/orange) – assign owner, plan mitigation
- 11-15 or 15-20: High (Orange/Red) active management, contingency plans
- 16-25 or 21-25: Critical/Extreme (Red) escalate, prioritize treatment immediately.

Risk levels and mitigation plans

Score	Risk level	Action required
1 - 4	Low	Monitor and manage routinely
5 – 9	Medium	Implement controls and review
10 – 16	High	Management attention required
17 – 25	Extreme	Immediate action required

Benefits of using a 5 * 5 matrix

1. Simple and easy to use
2. Helps prioritise risks
3. Supports decision making
4. Could be used in fields such as cybersecurity, (vulnerability assement and management), health and safety, engineering, and business risk management.

Note that a 5 * 5 risk matrix is used twice as underlisted

1. Before controls (inherent risk) to understand the seriousness of a hazard or impact.
2. After controls (residual risk) to verify that the risk has been reduced to an acceptable level.

Examples of assessing risks

1. You have discovered after assessment that the organization has weak passwords and with no password policy at all. Determine the risk at hand

Solution

Likelihood of attack = 4 which signifies that it is High

Impact if compromised = 5 which signifies Very High

Therefore, **Risk = Likelihood * Impact**

Risk = 4 * 5 = 20

This means that the risk score = **20 (Critical / Extreme)**

2. You have discovered that KMU stores non-sensitive or public information such as programs on offer, names of lecturers and which courses they handle. What would be the likelihood, impact and risk score

Solution

Likelihood = 3

Impact = 1

Risk = Likelihood * Impact

Risk = 3 * 1 = 3 and 3 is Low Risk

Examples of assessing risks

3. You have assigned a Network Engineer to check the cables on top of a two story building of the university library.

(a) Determine the risk score and risk level that your Technician could be involved in [4 Marks]

(b) Offer control measures that you could suggest as an ICT Team leader of the University [3 Marks]

(c) Reassess the risk (Residual Risk) [5 Marks]

(d) Convert the Residual risk in percentage

Solution

1. Identify the hazard: the hazard is that the Technician could fall from the roof top.
2. **Assess likelihood:** without any safety controls such as a helmet. Therefore, likelihood score in this case could be **4** which indicates "**likely**"
3. **Assess impact:** a fall from a two story building could result in injury, permanent disability or even death. Therefore, impact = **5 "Catastrophic"**
4. **Therefore, Risk = Likelihood * Impact = 4 * 5 = 20**
5. **This means that the score is 20 and the Risk Level is Extreme or critical**

Cont.

- Control measures could include the following:

1. Full body safety harnesses
2. Fall arrest lifelines
3. Worker training and supervision
4. Guardrails around roof edges

(c) **Solution**

- Residual risk = Remaining Likelihood * remaining impact

- After controls, Likelihood reduce from 4 (likely) to 2 (unlikely)
- Impact may remain at 5 (catastrophic) because a fall could still be fatal.
- New risk score could be Risk = 2 * 5 = 10
- Residual risk level or risk reduction could be High for 10 above. The risk has therefore reduced from 20 to 10.

(d) Percentage reduction = (20 – 10) / 20 * 100 = **50%**

Class work – Exam practice

1. After getting employed by a named University as a Network Manager, you discover that cables stretch across a walkway to the main offices.

(a) Determine the risk score and risk level that cables could cause (inherent risk) [4 Marks]

(b) Offer control measures that you could suggest a better alternative to the University [3 Marks]

(c) Reassess the risk (Residual Risk) (after controls)[5 Marks]

(d) Convert the Residual risk in percentage

2. Using a 5 * 5 risk matrix, determine which of the following is most likely to be classified as Extreme or critical

(a) Likelihood = 2, and impact = 2

(b) Likelihood = 3, and Impact = 3

(c) Likelihood = 4, and Impact = 4

(d) Likelihood = 2 and Impact = 5

Cont.

3. Discuss in detail, the primary purpose of a risk matrix in cybersecurity [2 Marks]

4. KMU identifies the following risks;

“Because the student portal server is missing critical patches, an external attacker could exploit known vulnerabilities to steal student data, causing regulatory breach and reputational damage”. The risk manager assess Likelihood = 4 (likely), Impact = 5 (catastrophic).

(a) Calculate the risk score [5 Marks]

(b) Classify the severity (Low /Medium/High/Critical) [2 Marks]

(c) Suggest one appropriate treatment strategy [1 Mark]

Cont.

- Use the following data for the above question
- Likelihood scare: 1 = Rare, 2= Unlikely, 3 = Possible, 4 = Likely, 5 = Almost certain
- Impact scale: 1 = Negligible, 2 = Minor, 3 = Moderate, 4 = Major, 5 = Catastrophic

Possible answers

(a) Likelihood = 3 (possible) and impact = 2 (Minor)

Risk = 3 * 2 = 6 as its score and Medium as its Risk Level

(c) Controls could be as follows:

1. Route cables under desks
2. Use cable covers
3. Improve house keeping
4. Safety awareness

After controls

Likelihood = 1 Impact = 2 Risk Residual = 1 * 2 = 2 and Level is Low

Determining acceptable Risk levels in a 5 * 5 Matrix

- An acceptable risk level (Risk tolerance or risk appetite) is the level of risk an organization is willing to accept without taking additional controls of mitigation measures.
- **Risk appetite**, **risk tolerance** and **risk threshold** have an underlining difference.
- **Risk appetite** is the strategic amount/type of risk the organization is willing to pursue/accept
- **Risk tolerance** is the acceptable variation around that appetite for specific objectives or units
- **Risk thresholds** are specific numeric trigger points such as ≥15 or ≤10 at which action must be taken
- To understand this, we need to define risk categories again. The following is an example of the above

Cont.

Risk score	Risk level	Acceptability
1 – 4	Low	Acceptable
5 – 9	Medium	Acceptable with monitoring
10 – 16	High	Requires mitigation
17 – 25	Extreme	Unacceptable

Cont.

2. **Consider legal and organizational requirements. This means that even if risks are low, it may not be acceptable if it:**

- Violate laws and regulations
- Breaches company policy on information security
- Could cause fatalities or serious injuries
- Create significant environmental damage
- Cause major reputational damage

3. **Use As Low As Reasonably Practicable (ALARP)**

- Here, questions such as if the risk could be reduced are asked
- Also, ask if the cost and effort of additional controls could be reasonable compared to the benefits
- If it is determined that the answer is yes, then additional controls should be implemented even when the risk is technically acceptable.

Risk response categories

- **Avoidance: T**he process of eliminating a risk by not engaging in an activity e.g. not clicking on a suspicious link send to our organizations email by an external attacker (phishing)
- **Acceptance:** Accepting an identified risk, meaning no cation will be taken when a risk assessment score is low.
- **Mitigation:** The process of taking steps to minimize the impact of a riks.
- **Transference:** Transferring the responsibility of a risk to a third party, such as insurance
- **Residual risk:** The risk that remains when after risk mitigation or transference activities have taken place.

Risk Tolerance (appetite) exam practice

1. Define risk tolerance [2 Marks]

- Risk tolerance is the acceptable deviation or variance around objectives that triggers action.

2. On a 5 * 5 risk matrix, scores 1-5 = Low, 6-12 = Medium, 13-25 = High. If management sets a risk tolerance threshold of No risks above 10 score, explain in detail, what should happen to a score of 11. [2 Marks]

- Exceeding tolerance requires action which could be mitigation, transfer, avoidance, or documented acceptance.

3. In an organization setup, who owns risk tolerance settings? [1 Mark]

- Board/Executives own risk appetite; Operational managers apply tolerance thresholds daily.

4. A computer lab at a university has a risk score pegged at 9 (Medium). The University's tolerance for the lab systems is ≤ 8. mention at least two appropriate management actions [2 Marks]

- Implement controls to reduce likelihood/impact so that the score boarders around ≤ 8
- Escalate to the system owner/risk owner for the treatment plan
- If retaining the risk, document a formal acceptance with compensating controls and review date

Exam practice cont.

5. The organization has given you three (3) risks

(a) R1: Likelihood 2, impact 3 – score 6

(b) R2: Likelihood 4, impact 4 – score 16

(c) R3: likelihood 3, impact 2 – score 6

- Policy: Tolerance ≤10 for all systems;
- Score ≥15 require immediate escalation
- Task: State the treatment decision for each risk and justify using tolerance / threshold rules [6 Marks]

(a) R1 (6): within tolerance since it is ≤ 10 therefore, monitor or apply routine controls

(b) R2 (16): Exceeds tolerance since 16 and is even above ≥15: therefore, escalate immediately and apply urgent containment or mitigation plans or seek formal acceptance at senior level.

(c) R3 (6) is within tolerance. Therefore, just monitor or apply routine controls

Vulnerability Risk Management / Assessment

- The following are some key words to risk management
- **Asset:** This could be people, property such as hardware and software, and information within an organization
- A **threat** is anything that can exploit a vulnerability, intentionally or accidentally, and obtain, damage, or destroy an asset.
- A **vulnerability** is a weakness of an asset that can be exploited by a threat.
- A **risk** is the potential for loss, damage, or destruction of an asset when a threat exploits a vulnerability
- **Risk** = Threat * Vulnerability meaning if a threat is able to exploit a vulnerability, then it results in a risk.
- Therefore, risk management is a process of identifying, assessing, monitoring, and limiting risk to an acceptable level.

Risk management

- A risk assessment, where risks are identified and assessed, is the first step in the risk management process.
- E.g.

1. Identify and categories your risks
2. Assess each risk’s probability and impact
3. Assign each risk a risk score and priorities according to risk scores
4. Reassess if possible.

Quantitative Risk Management/ Assessment in CYS

- **Single Loss Expectancy (SLE):** is a risk management metric that quantifies the financial impact of a single loss event. It represents the monetary value associated with the potential loss resulting from a specific security incident or threat. It happens to be a very important aspect of an organization in risk assessment and may help to make informed decisions regarding the allocation of resources for security measures.
- **Annualized Rate of Occurrence (ARO):** is a risk management metric that estimates the frequency with each a specific risk event is expected to occur within a one - year timeframe.
- **Annual Loss Expectancy (ALE):** is a risk management metric that estimates the financial impact or a potential risk over the course of a year.
- It provides organization with a quantitative assessment of the expected financial loss due to a specific risk.

Single Loss Expectancy (SLE)

- **SLE = Asset Value (AV) * Exposure Factor (EF)**
- **Asset Value (AV)** is the monetary value of the asset
- **Exposure Factor (EF)** is the percentage of the asset expected to be lost if the threat occurs. Note that it is usually expressed as a percentage or a decimal between 1 and 0. it is determined by **risk assessment** and **expert judgement** as it is difficult to know the exact impact of a future event. Organizations determine it by evaluating the following:

1. **Extent of damage:** How much of the asset would be affected if the threat materializes e.g. if a fire swept through the computer room, it might destroy at least 90% of the server computer . Therefore, 90% can be converted by dividing 90 by 100 = (0.9) .
2. **Historical data:** Reviewing past incidents and loses to estimate the percentage of damage caused by similar events
3. **Asset characteristics**: The asset value, redundancy, recoverability, and criticality influence the expected loss
4. **Existing controls:** Security measures, backups, insurance, fire suppression systems, and disaster recovery plans can reduce the percentage here.

- EF is not a probability of the event occurring. It is the percentage impact on the asset if the event does occur.

Common EF Values

Scenario	EF Example
Minor damage	10% = (0.1)
Moderate damage	30 – 50% (0.3 – 0.5)
Severe damage	70 – 90% (0.7 – 0.9)
Total Loss	100% (1.0)

Worked examples

For example, the server computer cost the organization K100,000 to purchase and the Exposure Factor (EF) is at 40%. Compute the Single Loss Expectancy (SLE). [4 Marks]

Solution

Given: AV = K100,000

EF = 40/100 = 0.4

Therefore **SLE = AV * EF**

SLE = 100000 * 0.4 = **K40,000**

- This means that a single successful incident would be expected to cause a loss of **K40,000**

Worked examples

- A Telecom Company has computer asset estimated at K50,000. However, there was a report of a threat in the form of a Ransomware attack. Risk analysts estimates that;
- Data backups would allow recovery of most valuable information.
- However, downtime and recovery costs would result in losing about 30% of the asset's value.
- Task: Calculate the Single Loss Expectancy (SLE) [4 Marks]

Solution

Given – AV = K50,000 and EF = 0.3

Therefore, SLE = AV * EF

SLE = 50,000 * 0.3 = **K15,000**

Exam practice SLE

1. Student's laptop asset value is at K2000 and it was reported that theft would result in a total loss because it is reported not to contain first cyber security safety rule measures such as passwords and was always left unguarded or well secured by the owner. Calculate the SLE for a student

- SLE = AV * EF = 2000 * 1 = K2000 [4 Marks]

2. Ransomware attack was reported at some bank in Chinsali. Consider the following data for your attention;

- Critical data value = 500,000
- Ransomware would affect 60% of the data.
- SLE = AV * EF = 500, 000 * 0.6 = K300, 000 [4 Marks]

3. A Telecom company has a data center for its smooth operation valued at $1000,000. However, fire destroys 80% of the facility. Compute SLE as an insurance company for them before a clam is made to establish how much loss incurred. [4 Marks]

- SLE = AV * EF = 1000, 000 * 0.8 = **$800,000**

Annual Rate of Occurrence (ARO)

- ARO is also defined as the expected number of times a specific threat or loss event will happen in one-year. It depends on **historical data**.
- ARO = $\frac{\boldsymbol{Number\ of\ past\ occurances}}{\boldsymbol{Number\ of\ years\ observed}}$

1. E.g. there has been a recorded theft of 22 laptops over 2 years

- **ARO =** 22/2 = **11 laptops per year**

2. A Mining company on the Copperbelt has reported that they experience an undesirable power outage about 4 times per year. Find ARO on their behalf [3 Marks]

- ARO = $\frac{\boldsymbol{Number\ of\ past\ occurances}}{\boldsymbol{Number\ of\ years\ observed}}$ = 4/1 = **4**

3. Student representative at Luapula Hostel at a named university has reported of theft occurrence of personal laptops of about 1 laptop stolen every 2 years . Compute ARO [3 Marks]

- ARO = $\frac{\boldsymbol{Number\ of\ past\ occurances}}{\boldsymbol{Number\ of\ years\ observed}}$ = ½ = **0.5**

ARO cont.

4. As a Regional IT manager, your subordinates have reported of floods happening in the area once every 10 years. Compute ARO for your desk report [3 Marks]

- **ARO** = $\frac{\boldsymbol{Number\ of\ past\ occurances}}{\boldsymbol{Number\ of\ years\ observed}}$ = 1/10 = **0.1**

5. A Bank receives successful phishing attacks about 6 times per year. Compute ARO for the Bank [3 Marks]

- **ARO** = $\frac{\boldsymbol{Number\ of\ past\ occurances}}{\boldsymbol{Number\ of\ years\ observed}}$ = 6/1 = **6**

6. The University is reported to have experienced 10 phishing incidents over 5 years. Compute ARO for them [3 Marks]

- **ARO** = $\frac{\boldsymbol{Number\ of\ past\ occurances}}{\boldsymbol{Number\ of\ years\ observed}}$ = 10/5 =**2**
- **The organisation can therefore, expect approximately 2 phishing incidents per year**.

ARO cont.

- ARO is used to estimate the likelihood of cyber incidents such as phishing attacks, ransomware infections, or data breaches
- It helps to prioritise security investigates and controls
- It helps with quality risks in financial terms

ARO summary

Event frequency	ARO
Once a month	12
Once a quarter	4
Twice a year	2
Once a year	1
Once every two years	0.5
Once every five years	0.2
Once every ten years	0.1
Once every 100 years	0.01

Annual Loss Expectancy (ALE)

- **ALE** as stated earlier, is the expected financial loss an organization will experience from a risk in one year.
- **ALE = SLE * ARO**

Example one

Server Computer theft of Asset Value K150,000 was reported to have been stolen indefinitely at night. Loss per incidence was K150,000 (SLE) and history has it that it happens once every two years. ARO = 0.5 [3 Marks]

- ALE = SLE * ARO
- ALE = 150,000 * 0.5 = **K75,000 per year**

Example two: Data breach is reported at a Government agency. SLE = K50,000 and ARO = 0.2 (once every 5 years) find the ALE [3 Marks]

- ALE = SLE * ARO = 50, 000 * 0.2 = **K10, 000**

Exam practice

Question one

Computer assets (hardware, networking devices, and software) of a university has an asset value of $400,000. Exposure factor is considered to be at 0.5 per year. In terms of ransomware and phishing attacks. The company however, has a risk tolerance band at ≤ 10 through analyst suggest the risk to be 12.

- Calculate the ALE for future ICT department planning in advance for the university [8 Marks]

Question two

1. Suggest the following risk management controls in terms of;

(a) Remediation [1]

(b) Mitigation [1]

(c) Avoidance [1]

(d) Tolerance [1]

(e) Transference [1]

(f) Residual risk [1]

Summary

Term	Meaning	Example
Single Loss Expectancy (SLE)	Loss from one incident	K5000
Annual Rate of Occupancy (ARO)	Number of incidents per year	1
Annual Loss Expectancy (ALE)	Expected annual Loss	K2000